

Manual 10 - Implementación Controlada de NIST RMF y SP 800-53

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: 9c420201ad6822c594e74c7f7508e00b53472f4c | Idioma: es-419 | se mantienen los límites de autorización RMF y de decisión humana.

Límite de aseguramiento: Este manual operacionaliza conceptos de NIST RMF y SP 800-53, pero no autoriza un sistema, no crea certificación NIST, no demuestra efectividad de controles, no establece cumplimiento legal ni sustituye a una autoridad de autorización responsable o a un evaluador competente. La adaptación, evaluación, autorización, excepciones, riesgo residual y decisiones materiales requieren juicio humano responsable.

Rutas de implementación

Manual 10 — Rutas de implementación

Borrador controlado asistido por máquina (es-419). La edición en inglés sigue siendo la fuente controlada. Esta localización no constituye aprobación semántica o terminológica humana y permanece sujeta a la compuerta de revisión humana antes de publicación.

Esencial

Use esta ruta para sistemas más pequeños o con alcance acotado. Expectativas mínimas de implementación:

- límite del sistema, propietario, contexto de misión/negocio y roles responsables definidos;
- responsables de cada paso de RMF y puntos de decisión documentados;
- categorización apropiada y selección inicial de línea base de controles;
- justificación documentada de la adaptación;
- identificación clara de controles comunes, específicos del sistema e híbridos;
- evidencia de implementación para los controles seleccionados;
- planificación de evaluación basada en riesgo y seguimiento de hallazgos;
- decisión explícita de autorización por la autoridad humana responsable;
- frecuencia de monitoreo continuo, excepciones y seguimiento de POA&M.

Estructurada

Use esta ruta para múltiples sistemas, servicios compartidos, entornos regulados o riesgo organizacional material. Añada:

- estrategia de riesgo a nivel organizacional vinculada con decisiones a nivel de sistema;
- gobierno reutilizable de controles comunes y evidencia de herencia;
- planificación de seguridad, privacidad y C-SCRM del sistema alineada con SP 800-18 Rev. 2;
- registros formales de adaptación de controles y overlays cuando corresponda;
- evidencia de evaluación estructurada alineada con SP 800-53A;
- evidencia legible por máquina y OSCAL cuando sea operacionalmente útil;
- gestión formal del paquete de autorización;
- monitoreo continuo recurrente y activadores de reevaluación;
- gobierno de excepciones, aceptación de riesgo y POA&M con vencimiento y responsables de remediación.

Mejorada

Use esta ruta para entornos de alto impacto, misión crítica, escala empresarial, alta regulación o interconexión. Añada:

- agregación de riesgo entre sistemas e informes de riesgo empresarial;
- gobierno riguroso de proveedores de controles comunes y validación de herencia;
- evaluación independiente y pruebas técnicas especializadas cuando el riesgo lo justifique;
- recopilación automatizada de evidencia con controles de procedencia;
- artefactos de sistema/control/evaluación respaldados por OSCAL cuando sea factible;

- monitoreo continuo de controles vinculado con cambios materiales y estado de autorización;
- criterios formales de autorización continua cuando la organización los adopte;
- aceptación ejecutiva de riesgo residual material;
- resiliencia, cadena de suministro, privacidad y riesgo de dependencias integrados en decisiones de autorización.

Ruta de evidencia RMF

Gráfico de memoria del Manual 10 1

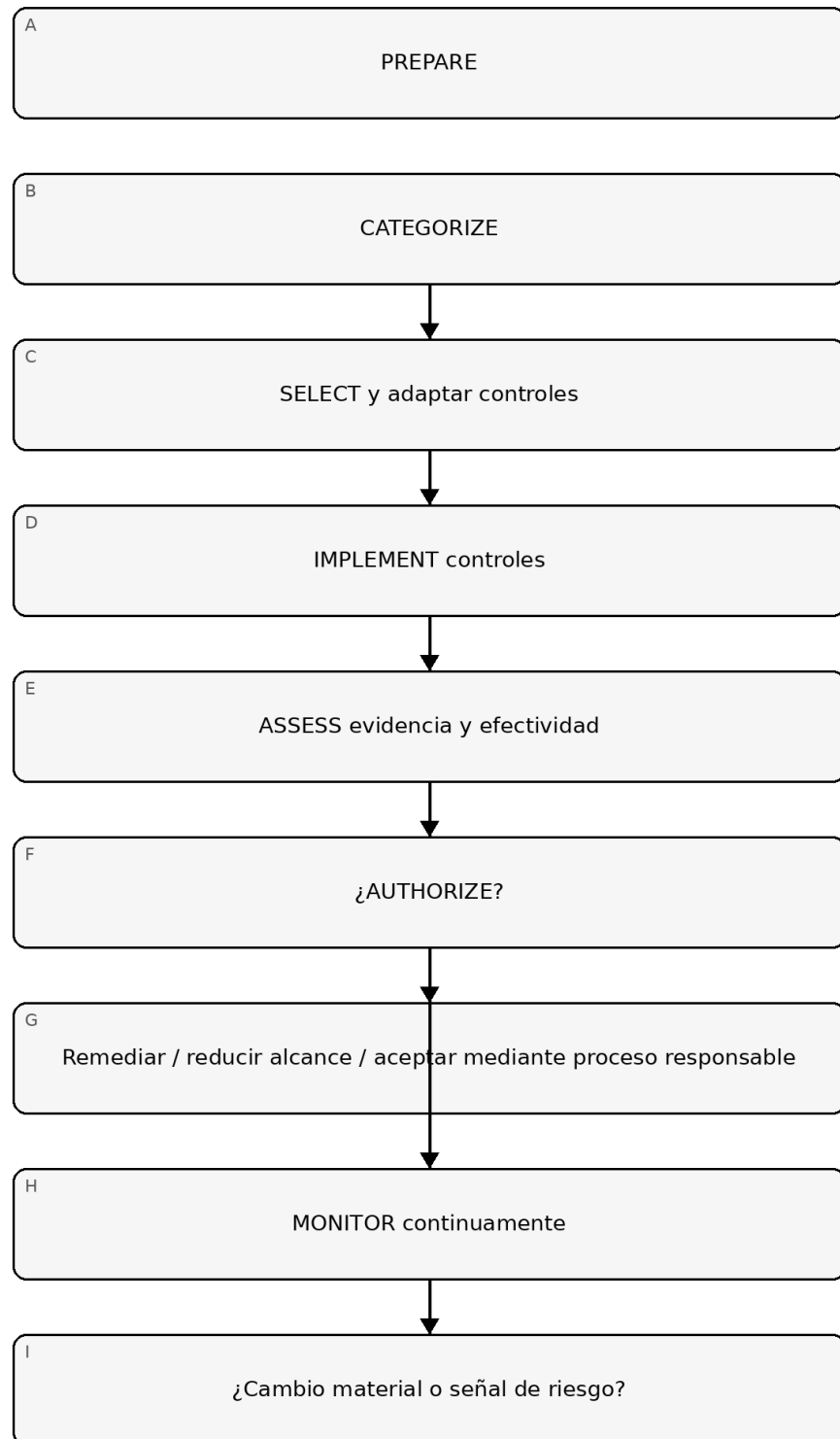


Figura 1. Gráfico de memoria de implementación RMF

Explicación accesible: RMF es un ciclo continuo de evidencia y decisión. Una decisión negativa de autorización devuelve el trabajo a remediación o tratamiento responsable del riesgo en vez de crear aprobación automática. El monitoreo devuelve los cambios materiales a preparación y reevaluación.

Cadena de evidencia de controles

Gráfico de memoria del Manual 10 2

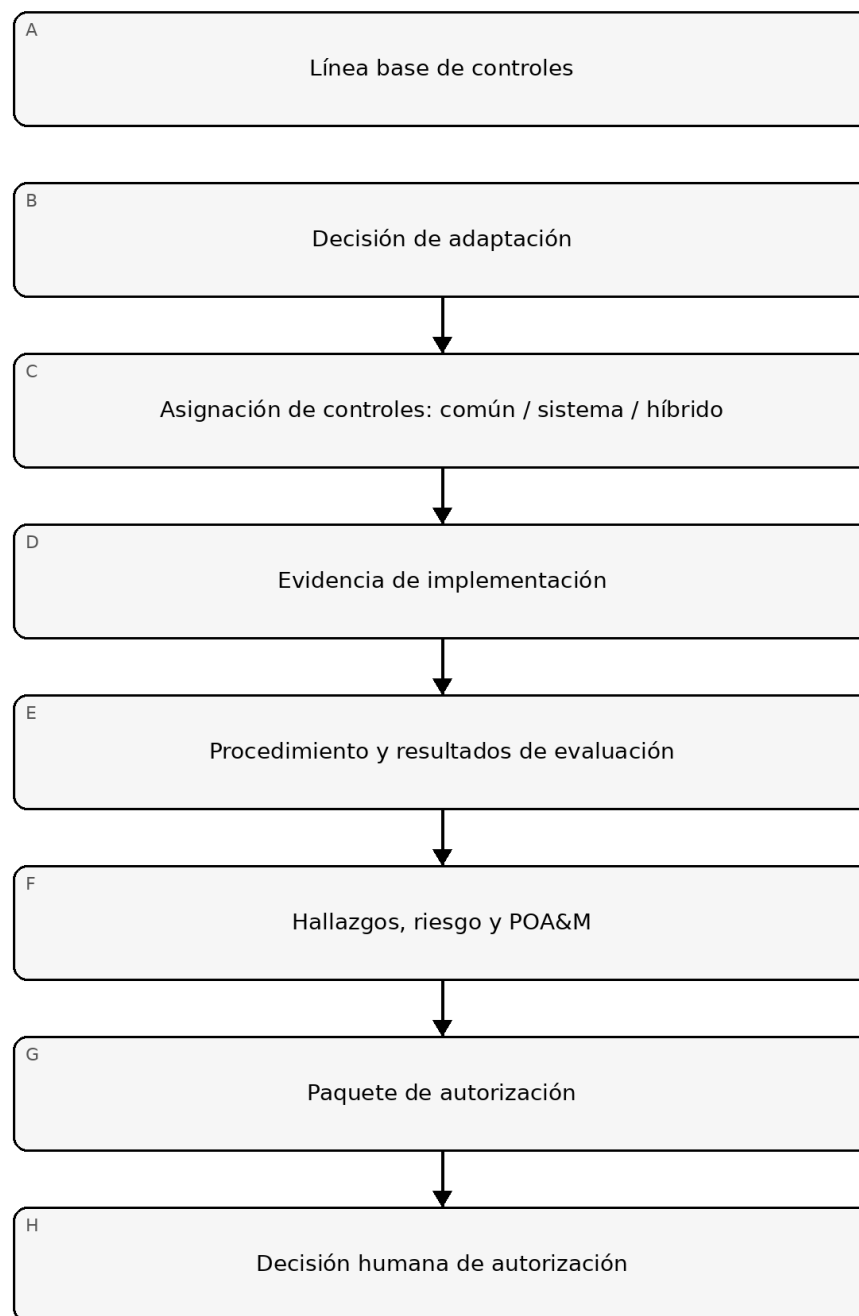


Figura 2. Gráfico de memoria de implementación RMF

Explicación accesible: La evidencia debe conectar selección de línea base, adaptación, asignación, implementación, evaluación, hallazgos, remediación y la decisión final de autorización responsable. Ninguna lista de verificación o flujo automatizado sustituye esa cadena.

Cadena de planificación y evidencia legible por máquina

Gráfico de memoria del Manual 10 3

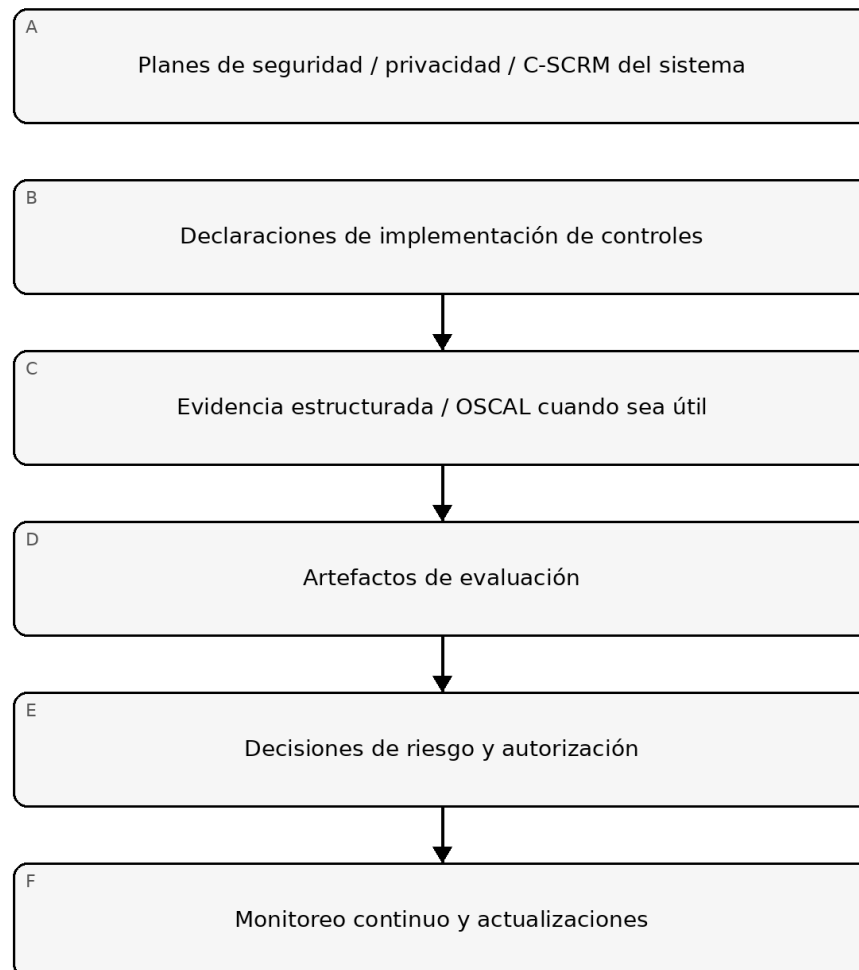


Figura 3. Gráfico de memoria de implementación RMF

Explicación accesible: Los planes del sistema y las declaraciones de implementación deben permanecer conectados con la evidencia de evaluación, decisiones de riesgo, autorización y monitoreo. Los formatos legibles por máquina pueden mejorar la trazabilidad, pero no crean aseguramiento por sí mismos.

Límite de control

El manual es basado en riesgo, adaptable y basado en evidencia. No debe presentar los controles SP 800-53 como universalmente obligatorios fuera de su contexto de gobierno aplicable, no debe tratar la línea base como una lista de verificación sin adaptación y no debe implicar que aprobar QA del repositorio o una prueba automatizada de controles constituye autorización, certificación o aceptación de riesgo.

Manual controlado de 32 capítulos

Capítulo 01 — Propósito del RMF y arquitectura de decisiones

Use RMF como un ciclo operativo de gestión de riesgos que conecta objetivos de misión, contexto del sistema, riesgos de seguridad y privacidad, implementación de controles, evidencia de evaluación, decisiones de autorización y monitoreo continuo. Evite tratarlo como un ejercicio documental de una sola vez.

Defina roles responsables, límites del sistema, autoridades de decisión, rutas de escalamiento, expectativas de evidencia y la relación entre decisiones de riesgo organizacionales y del sistema.

Capítulo 02 — PREPARAR a nivel organizacional

Establezca supuestos de riesgo, gobierno, tolerancia al riesgo, estrategia de controles comunes, expectativas de cadena de suministro, arquitectura empresarial, servicios compartidos, estrategia de evaluación y estrategia de monitoreo antes de evaluar sistemas individuales.

La evidencia debe mostrar propiedad, criterios de riesgo aprobados, supuestos de dependencia, proveedores de controles comunes, evidencia reutilizable y riesgos empresariales no resueltos.

Capítulo 03 — PREPARAR a nivel del sistema

Defina misión del sistema, dueño de negocio, dueño del sistema, límite de autorización, entorno operativo, usuarios, datos, interfaces, dependencias, proveedores, servicios heredados y ciclo de vida esperado.

Documente supuestos y desconocidos explícitamente. La incertidumbre de límites, propiedad ambigua o información faltante de dependencias debe permanecer visible como riesgo.

Capítulo 04 — Responsabilidad de partes interesadas y roles

Identifique al funcionario autorizador, función ejecutiva de riesgo, dueño del sistema, dueño de información, proveedores de controles, evaluadores, responsables de seguridad/privacidad, arquitectos, ingenieros, operaciones, legal, privacidad, cadena de suministro y representantes de negocio necesarios.

Separe suficientemente responsabilidades de implementación, evaluación y autorización para preservar desafío independiente y responsabilidad decisional.

Capítulo 05 — Caracterización de información y sistema

Caracterice tipos de información, propósito de procesamiento, usuarios, tecnologías, ubicaciones, interfaces, flujos de datos, conexiones externas, dependencias cloud o de servicios compartidos, OT cuando aplique y relaciones de cadena de suministro.

La caracterización debe soportar análisis de seguridad y privacidad y mantenerse conforme cambia el sistema.

Capítulo 06 — CATEGORIZAR impacto de seguridad

Categorice el sistema usando métodos aplicables de análisis de impacto y política organizacional. Registre el razonamiento de las determinaciones de confidencialidad, integridad y disponibilidad, incluidas consecuencias de misión y dependencias.

La categoría es una entrada a la decisión, no un sustituto del análisis de amenazas, privacidad o riesgo de negocio.

Capítulo 07 — Privacidad y consideraciones adicionales de impacto

Integre riesgo de privacidad, obligaciones legales, sensibilidad de datos, daños a la misión, seguridad, requisitos contractuales, exposición de cadena de suministro y otro contexto que pueda exigir controles o protecciones adicionales.

Documente dónde análisis separados de privacidad, riesgo o revisión especializada afectan la línea base de controles o el paquete de autorización.

Capítulo 08 — Puerta fail-closed de PREPARAR/CATEGORIZAR

No proceda como si el sistema estuviera listo para selección de controles cuando el límite de autorización no está resuelto, falta propiedad responsable, las determinaciones de impacto carecen de soporte, las dependencias críticas son desconocidas o los supuestos organizacionales contradicen la realidad del sistema.

Las verificaciones automatizadas pueden validar registros y relaciones requeridos, pero la categorización, alcance y responsabilidad requieren juicio humano competente.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 09 — SELECCIONAR la línea base inicial de controles

Elija una línea base inicial apropiada mediante política organizacional y guía NIST aplicable. Registre fuente, contexto de impacto, supuestos, controles heredados, controles comunes, overlays y otros requisitos que influyen en el conjunto inicial.

La línea base inicial no es el conjunto final; es el punto estructurado para adaptación y refinamiento basado en riesgo.

Capítulo 10 — Decisiones de adaptación y alcance

Adapte controles transparentemente según aplicabilidad, tecnología, misión, riesgo, entorno, salvaguardas compensatorias, obligaciones legales o contractuales y tolerancia al riesgo.

Cada decisión sustantiva debe registrar razonamiento, autoridad, controles afectados, supuestos, riesgo residual, dependencias y condiciones de revisión. La adaptación no debe convertirse en eliminación no documentada de controles.

Capítulo 11 — Controles comunes, específicos e híbridos

Clasifique controles según dónde residen responsabilidad e implementación. Identifique proveedores de controles comunes, porciones heredadas, responsabilidades específicas del sistema, límites híbridos y dueños de evidencia.

Las afirmaciones de herencia deben identificar proveedor real, alcance, evidencia, aplicabilidad, estado y parámetros o responsabilidades residuales del sistema.

Capítulo 12 — Parametrización y declaraciones de implementación

Traduzca controles seleccionados en declaraciones específicas del sistema, parámetros, roles, tecnologías, procedimientos y expectativas de evidencia. Evite repetir objetivos genéricos sin explicar cómo el sistema los satisface.

Las declaraciones deben ser comprobables, actuales, versionadas y trazables a arquitecturas, configuraciones, procedimientos, logs, tickets, contratos u otra evidencia.

Capítulo 13 — Planificación de seguridad, privacidad y C-SCRM

Mantenga documentación que explique contexto del sistema, controles seleccionados, enfoque de implementación, consideraciones de privacidad, dependencias de cadena de suministro, supuestos de riesgo, responsabilidades y fuentes de evidencia.

Use la guía NIST vigente para estructurar registros vivos, no documentos estáticos creados solo para eventos de autorización.

Capítulo 14 — IMPLEMENTAR controles en el entorno operativo

Implemente controles seleccionados en tecnología, procesos, personas, instalaciones, contratos y proveedores según corresponda. Configuración, procedimientos, límites de acceso, monitoreo, capacitación, recuperación y recolección de evidencia deben reflejar el diseño aprobado.

La finalización de implementación debe basarse en evidencia, no solo en estado de tareas.

Capítulo 15 — Evidencia de implementación y procedencia

Para cada control material preserve evidencia suficiente de qué se implementó, dónde, por quién, cuándo, bajo qué configuración o versión y con qué limitaciones.

La evidencia debe ser relevante, actual, atribuible, resistente a manipulación cuando corresponda y vinculada al alcance exacto. La evidencia generada por máquinas requiere procedencia e interpretación humana cuando interviene juicio.

Capítulo 16 — Puerta fail-closed de SELECCIONAR/IMPLEMENTAR

No trate el conjunto de controles como listo cuando falta razonamiento de adaptación, la responsabilidad por controles heredados es ambigua, las declaraciones no son comprobables, parámetros críticos están indefinidos o la evidencia no puede trazarse al sistema real.

La automatización puede apoyar mapeo y recolección de evidencia, pero no establecer por sí sola aplicabilidad, implementación efectiva o riesgo residual aceptable.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 17 — Planificación de la evaluación

Defina alcance, objetivos, controles seleccionados, procedimientos, fuentes de evidencia, expectativas de independencia, muestreo, entornos de prueba, participantes, cronograma y limitaciones antes del trabajo de campo.

El plan debe distinguir preguntas de diseño, implementación y efectividad operativa e identificar dónde los controles heredados o comunes requieren evidencia separada.

Capítulo 18 — Suficiencia y calidad de evidencia

Evalúe relevancia, confiabilidad, actualidad, integridad, alcance, procedencia y aplicabilidad de la evidencia. Un artefacto válido puede ser insuficiente si cubre otro entorno, periodo, servicio o límite de responsabilidad.

Documento supuestos, evidencia no disponible, contradicciones e incertidumbre en lugar de ocultarlos tras etiquetas de aprobado/reprobado.

Capítulo 19 — Procedimientos y pruebas de evaluación

Use examen, entrevista y pruebas apropiadas para determinar si los controles están correctamente implementados, operan según intención y producen el resultado esperado. Adapte procedimientos a tecnología, riesgo, contexto y evidencia disponible.

Las pruebas automatizadas pueden mejorar cobertura y repetibilidad, pero el juicio del evaluador sigue siendo necesario para interpretación, alcance, limitaciones y significado.

Capítulo 20 — Hallazgos, debilidades y severidad

Registre hallazgos con controles afectados, alcance, evidencia, condición, estado esperado, consecuencia de riesgo, causa raíz cuando se conozca, racional de severidad, dueño, ruta de remediación y requisitos de validación.

No reduzca hallazgos a excepciones de checklist sin explicar riesgo material o impacto de implementación.

Capítulo 21 — Informe de evaluación y paquete de riesgo

Prepare un paquete que distinga alcance probado, procedimientos ejecutados, evidencia revisada, hallazgos, limitaciones, dependencias de controles heredados, preguntas abiertas y conclusiones del evaluador.

El paquete debe soportar decisiones de riesgo sin exagerar el aseguramiento más allá de la evidencia recopilada.

Capítulo 22 — Paquete de autorización

Reúna planes del sistema, evidencia de implementación, resultados de evaluación, análisis de riesgo, elementos POA&M, excepciones, dependencias de controles comunes, declaraciones de riesgo residual y restricciones operativas relevantes.

El paquete debe exponer riesgo abierto e incertidumbre material en lugar de optimizar por una apariencia limpia.

Capítulo 23 — Decisión de autorización y condiciones

El funcionario autorizador o autoridad responsable decide si el riesgo residual es aceptable para misión, alcance, entorno y periodo definidos. La decisión puede autorizar, autorizar con condiciones, exigir remediación, restringir operación, diferir o negar autorización.

Registre autoridad, fecha, alcance, evidencia considerada, riesgos materiales, condiciones, expiración o detonantes de revisión y seguimiento requerido.

Capítulo 24 — Puerta fail-closed de EVALUAR/AUTORIZAR

No trate un sistema como listo para autorización cuando el alcance de evaluación es materialmente incompleto, hallazgos significativos no están sustentados o resueltos, la calidad de evidencia es inadecuada, la responsabilidad de autorización es ambigua o el riesgo residual está oculto al decisor.

La automatización puede apoyar evaluación y ensamblaje del paquete, pero no sustituye juicio competente ni la decisión humana responsable de autorización.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.

Capítulo 25 — Estrategia de monitoreo continuo

Defina qué controles, riesgos, configuraciones, vulnerabilidades, eventos, dependencias, proveedores, fuentes de evidencia y cambios del sistema requieren monitoreo continuo. Establezca frecuencia, detonantes, responsables, retención, informes, umbrales y escalamiento.

El monitoreo debe priorizar riesgo y cambio, no solo recolectar métricas recurrentes.

Capítulo 26 — Impacto del cambio y control de configuración

Evalúe cambios materiales de sistema, arquitectura, software, datos, identidades, proveedores, cloud, interfaces, misión y controles por su impacto en controles seleccionados, evidencia, conclusiones de evaluación y condiciones de autorización.

Los cambios que invaliden evidencia o supuestos de riesgo deben reabrir la revisión afectada.

Capítulo 27 — Gobierno de POA&M y remediación

Gestione Planes de Acción e Hitos como registros responsables de tratamiento de riesgo. Cada elemento debe identificar debilidad, sistema o control afectado, importancia del riesgo, dueño, acción, hitos, fechas, controles provisionales, dependencias, evidencia requerida y ruta de escalamiento.

Las extensiones repetidas de fecha sin análisis actualizado y aprobación no deben tratarse como remediación efectiva.

Capítulo 28 — Evaluación continua y actualización de evidencia

Actualice evidencia según riesgo, volatilidad del control, resultados de monitoreo, incidentes, cambios, expiración y condiciones de autorización. Reevalúe cuando la evidencia quede obsoleta, cambie el alcance, la implementación se desvíe o aparezca nueva información de riesgo.

El monitoreo continuo no elimina la necesidad de evaluación humana focalizada y desafío independiente.

Capítulo 29 — Monitoreo de controles comunes y riesgo heredado

Siga proveedores de controles comunes y controles heredados durante el periodo de autorización. Monitoree cambios del proveedor, interrupciones, hallazgos, cambios de alcance, resultados y vigencia de evidencia que puedan alterar el riesgo de sistemas dependientes.

Un sistema no debe seguir acreditando protección heredada cuando la evidencia del proveedor ya no respalda esa afirmación.

Capítulo 30 — OSCAL y evidencia legible por máquina

Use OSCAL u otros formatos legibles por máquina cuando corresponda para mejorar trazabilidad, intercambio, validación, automatización y procedencia de catálogos, perfiles, planes, evaluaciones y evidencia relacionada.

Los registros deben preservar identidad de fuente, versión, alcance, autoría, marcas de tiempo, limitaciones y límites de decisión humana. La automatización mejora consistencia, pero no crea autoridad de autorización.

Capítulo 31 — Soporte a autorización continua y decisiones de riesgo

Use monitoreo y evidencia actualizada para apoyar decisiones continuas, incluida continuidad de operación, condiciones, remediación, restricciones, reevaluación o reautorización cuando lo requieran política o cambio material.

La autorización continua debe significar disponibilidad continua de evidencia y gobierno de calidad decisonal, no aprobación automática por herramientas.

Capítulo 32 — Liberación del manual y límite de aseguramiento

Manual 10 solo se cierra cuando verificación de fuentes, maestro inglés de 32 capítulos, revisión técnica/editorial/de mapeo, localización es-419 y pt-BR con revisión semántica humana, accesibilidad, QA DOCX/PDF, seguridad del repositorio/workflows, manifiesto/checksums/procedencia, reconciliación exact-head y Aprobación Humana Final de Liberación estén completas para el mismo candidato exacto.

La finalización no autoriza ningún sistema real, no certifica cumplimiento y no elimina riesgo residual.

Estado de localización: borrador controlado; revisión semántica humana obligatoria antes de aprobación o publicación.